

Training Day 12 Report

Date: 28 June 2025

Module Name: System Hacking & Password Security

Mode: Practical + Theoretical

Main Focus of the Module

Day 13 focused on understanding how **passwords are stored and secured in Windows systems**, the types of **password attacks**, and how ethical hackers extract and crack password hashes during **system hacking**. We also learned about tools like **pwdump7** and the theory behind **password protection mechanisms**.

Topics Covered

What is System Hacking?

- **System hacking** is the process of **gaining unauthorized access to systems**, often by bypassing authentication using **password cracking** or exploiting **vulnerabilities**.
 - It involves 4 key steps:
 1. **Gaining Access**
 2. **Escalating Privileges**
 3. **Maintaining Access**
 4. **Covering Tracks**
-

Password Storage in Windows

Security Accounts Manager (SAM)

- Windows stores user account details and password hashes in the **SAM file** located at:

```
makefile
Copy code
C:\Windows\System32\Config\SAM
```

- This file is **locked** when Windows is running.
-

☐ Hashing Mechanism

- **Hashes stored in SAM are not plain passwords**

- Hashes are generated using:
 - **LM Hash (older systems)** – Easily breakable, split into two 7-character pieces
 - **NTLM Hash** – More secure, uses MD4 hashing
 - Windows uses **NTLMv2** in newer versions
-

Tools Used for Password Dumping

pwdump7

- Tool to extract password hashes from the Windows SAM file
- Requires administrative privileges or offline access

Usage:

```
cmd
Copy code
pwdump7.exe > hashes.txt
```

Result:

- Extracted user account info along with hashed passwords in the format:

```
ruby
Copy code
username:RID:LMhash:NThash:::
```

Other Tools for Dumping and Cracking

Tool	Purpose
Mimikatz	Dumps plaintext passwords, hashes, PINs, tickets from memory
Cain & Abel	Graphical tool for Windows password cracking
John the Ripper	Cracks hashes using dictionary/brute force
Hashcat	GPU-based high-speed hash cracker

Types of Password Attacks

1. **Brute Force Attack**
 - Tries all possible combinations
 - Time-consuming but guaranteed success if time allows
2. **Dictionary Attack**

- Tries words from a pre-defined wordlist
 - Faster than brute force, but misses complex/random passwords
 - 3. **Rainbow Table Attack**
 - Uses precomputed hash tables
 - Fast but requires large storage
 - 4. **Hybrid Attack**
 - Mix of dictionary + symbols/numbers
 - More effective against semi-complex passwords
 - 5. **Credential Stuffing**
 - Uses leaked usernames/passwords from previous breaches
-

Password Security Theory

- **Strong Password Policy Includes:**
 - Minimum 12 characters
 - Mix of uppercase, lowercase, numbers, and symbols
 - Avoid common words, names, dates
 - No reuse across platforms
 - **Salting:**
 - A random string added to a password before hashing
 - Prevents use of rainbow tables
 - **Multi-Factor Authentication (MFA):**
 - Adds extra layer of security beyond passwords
-

Hands-On Practice Summary

- Used `pwdump7` on a test Windows VM to extract SAM hashes
 - Compared LM and NTLM hash formats
 - Tried loading hashes into John the Ripper for cracking
 - Observed cracking time difference for strong vs weak passwords
-

Key Takeaways

- Windows does not store passwords in plaintext—only hashes
- Passwords can be cracked with enough time or weak policies
- Hash dumping tools require **privileged access**, often obtained via local exploits
- Strong password policies and MFA are essential to defend against system hacking
- Ethical hackers must responsibly test systems and document vulnerabilities without causing harm